

CLOISTER

Confining documents against machine ingestion — a four-layer architecture combining post-quantum sealed envelopes, posture-gated decryption, machine-hostile rendering, and collusion-resistant leak attribution.

Once a file's bytes reach a language model, nothing can un-read them. Every serious defence must therefore act *before* that moment, or make the act *attributable* afterwards. CLOISTER does both. It replaces the industry's identity-based question — *who* is opening this document? — with a posture-based one: *does the runtime asking for this key have any path by which the plaintext could leave?* Keys are released only into a process with no network egress, no clipboard, no capture surface and no debugger. When a document must nonetheless travel, its text layer is replaced by a fluent, per-recipient decoy, so automated extraction pipelines terminate confidently on the wrong document — and any copy that escapes carries a fingerprint that names the leaker from a single paragraph.

This paper specifies the architecture, reports measurements from a working proof of concept of all four layers, and is explicit about the one thing no system of this kind can prevent.

0 / 24

sensitive terms recovered by
standard text-extraction
pipelines

1,660 B

constant envelope overhead,
hybrid X25519 + ML-KEM-768

16

egress syscalls denied to any
process that touched plaintext

5 %

of a document is enough
to name the leaker

Contents

1	The problem is the invisible moment	10	Ethics, law and misuse
2	Threat model and calibrated claims	11	Regulatory and market context
3	Five design principles	12	Roadmap and standardisation
4	Architecture: four layers	13	Limitations and open problems
5	Implementation and measurements	14	Conclusion
6	Cross-platform enforcement	A	Envelope schema and notation
7	What is actually new here	B	Parameter tables
8	Deployment postures	C	Reproducibility
9	Security analysis		References

Executive summary

The market has answered a question nobody asked. A well-funded new category of "AI data-loss prevention" now sits at network egress points and inside managed browsers, watching for the moment an employee pastes something into a chatbot. That control works exactly as long as the file stays on a managed device, inside a managed browser, on a managed network. The professor emailing an exam, the associate sending a draft to co-counsel, the researcher sharing a preprint under embargo — none of them are protected by any of it.

CLOISTER starts from a different premise: **protection has to travel with the document, and the document has to be hostile to machines while remaining faithful to people.** Four layers, each independently deployable:

- **P1 — The Envelope.** A hybrid post-quantum sealed container (X25519 + ML-KEM-768) whose content key is derived over a digest of a *runtime posture policy*. Downgrading the policy destroys the key, even for an adversary holding the distributor's signing key. Measured: 1,660 bytes of constant overhead, 636 MB/s unseal.
- **P2 — The Membrane.** Keys are released only into a process that has already, irreversibly, given up the ability to leak: empty network namespace, 16 egress-related syscalls returning EPERM, no ptrace, no /proc/pid/mem, capture-excluded window surface. The filter survives execve, so it also covers an agent runtime or MCP server that attaches downstream. Measured: no detectable rendering overhead.
- **D — Semantic Chaff.** When a document must leave the perimeter, CLOISTER decouples what a human sees from what a machine reads. The rendered glyphs are the true document; the text layer is a fluent, length-congruent, per-recipient decoy. Measured: standard extraction pipelines recover **0 of 24** probed sensitive terms and cannot detect that they were fooled — the decoy's compression profile sits inside the natural-language band, whereas classic gibberish-producing tricks are conspicuously anomalous.
- **T — Traitor Tracing.** Every copy carries a Tardos codeword embedded redundantly across independent channels. The fingerprint rides two independent channels: the decoy itself, and a sub-perceptual displacement of inter-word spacing that survives being photographed. Measured: with a redundancy schedule of 40, a leaked fragment as small as **5%** of the document names at least one of five colluders with probability at least **0.96** against the worst of five collusion strategies, with zero false accusations across 3,000 trials.

Two more layers followed. For the academic case, one that inverts the problem: rather than trying to stop a student feeding an assignment to a model, attest the human writing process cryptographically, disclosing only zero-knowledge predicates over an edit trail that never leaves their device (§4.6, measured in §5.8). And Layer V, which attacks optical capture by exploiting how displays are *sampled* rather than how pages look. It defeats a single screenshot on any platform with no help from the operating system, and with a shutter at the reader it reduces an ordinary camera's capture to provably uniform grey (§4.7, §5.9).

THE HONEST PART, STATED ONCE, UP FRONT

A person who is authorised to *read* a document can always photograph the screen, retype it, or dictate it. CLOISTER does not prevent that and no system can. What it does is close every *low-effort, high-fidelity, unattributable* path — which is where essentially all real incidents live — and guarantee that whatever escapes through the remaining high-effort paths is traceable. Section 2.4 states this as a formal property rather than a slogan.

1 The problem is the invisible moment

The user's own framing was correct and is worth restating precisely, because it rules out most of the market's answers: *a model just reads the bytes*. There is no instruction you can embed in a file that reliably stops a competent inference pipeline from processing it. Prompt-injection-style "do not read this" markers are unreliable against hardened systems, are trivially stripped, and — as Section 10 argues — are an attack on a third party's system rather than a defence of your own. Content-side pleading does not work.

What makes AI ingestion different from ordinary leakage is not the reading. It is that the moment of ingestion is **invisible** and **unattributable**. A document dragged into a chat window leaves no trace in the document's own history, produces no access-log entry the owner can see, and — once the model has answered — is indistinguishable from the user having simply read the file. Traditional confidentiality controls assume that copying leaves evidence. Here it leaves none.

1.1 Three constituencies, three different losses

Table 1 — What each user class actually stands to lose

Constituency	The asset	The specific failure	Confidentiality horizon
Legal	Attorney work product, privileged communications, sealed filings, unfiled drafts	Disclosure to a third-party service risks subject-matter waiver of privilege; discoverable chat logs create a new evidentiary surface	Decades. Privilege does not expire.
Academic	Exams and assignments under an AI-prohibited rubric; unpublished manuscripts; peer-review material	Assessment validity collapses; embargoed results are pre-empted; reviewer confidentiality broken	Weeks to years
Professional / IP	Trade secrets, unfiled patent material, M&A documents, source code	Trade-secret status requires "reasonable measures" — uncontrolled AI ingestion may itself destroy protectability	Indefinite while secret

Note the asymmetry in the last column. Legal and trade-secret material has a confidentiality horizon measured in decades, which is why Section 4.2 insists on post-quantum key establishment rather than treating it as future-proofing theatre. An envelope captured in 2026 and opened in 2046 has still breached privilege.

1.2 The 2026 ingestion surface

Enumerating the actual paths matters, because a control that covers three of them and misses the other seven is not a control. As of mid-2026 a document reaches a model through:

Deliberate, user-initiated. Upload into a consumer chat interface; paste into a chat box; a browser-resident assistant reading the active tab; "explain this document" in a PDF reader.

Ambient, platform-initiated. Productivity-suite assistants indexing document stores by default; OS-level assistants that periodically capture the screen; on-device NPU models on "AI PC" hardware; search indexes that now embed document content into vector stores.

Agentic, machine-initiated. Coding assistants that read an entire repository for context; autonomous agents with filesystem tools; Model Context Protocol servers granted directory access; CI pipelines that summarise artefacts.

Incidental. Screenshot-to-model workflows; email integrations; a colleague's device that is less controlled than yours; a third-party vendor's processing pipeline.

The agentic column deserves emphasis because it is both the newest and the least governed. MCP's rapid adoption has produced a steady stream of file-exposure vulnerabilities: sandbox-escape and symlink-bypass flaws in the reference filesystem server (CVE-2025-53109 / CVE-2025-53110), a command-injection flaw in `mcp-remote` with several hundred thousand downstream installs (CVE-2025-6514), prompt-injection-driven exfiltration of private repository contents through an over-privileged token, and a 2026 design flaw in the STDIO transport producing a cluster of further CVEs.^[7] ^[8] The Cloud Security Alliance characterised the situation in May 2026 as systemic rather than incidental, and the NSA has published protocol-specific guidance.^[9] The relevant point for this paper is not that MCP is unusually insecure — it is that **the file-reading party is increasingly not a person**, so controls premised on user intent have no purchase.

1.3 Why the existing three answers miss

Table 2 — Existing control families and their structural blind spot

Family	How it works	Where it stops working
AI DLP gateways Prompt Security (acquired by SentinelOne, announced Aug 2025, ~\$250M), Harmonic, Witness AI, Zscaler / Netskope / Palo Alto AI modules	Inspect prompts and uploads at a network egress point or via a managed-browser extension; classify and block	Requires the traffic to be visible. Blind to unmanaged devices, personal machines, the recipient's organisation, on-device models, and any agent that reads the file locally. Enforcement ends at the perimeter; the document does not.
Information rights management Microsoft Purview Information Protection, Adobe document DRM, Virtru, Seclore, Fasoo	Encrypt the file; a licensed client enforces per-identity rights such as "do not copy", "do not forward"	Authenticates <i>identity</i> , not runtime posture. An authorised user on a compromised or merely permissive machine is fully authorised to decrypt into a process that can then do anything, including hand the plaintext to a local agent. Microsoft's own endpoint attempt, Windows Information Protection, was sunset in 2022. ^[6]
AI-text detection Turnitin and similar	Statistically classify submitted text as machine-generated	Wrong primitive and unreliable. Detectors are biased against non-native English writers ^[13] and Vanderbilt among others disabled Turnitin's AI detector in 2023 over false-positive risk. ^[12] A control that produces false accusations against students is worse than no control.

All three share one assumption: that the defender controls the environment in which the document is opened. CLOISTER's design question is what remains possible when that assumption is dropped.

2 Threat model and calibrated claims

2.1 Adversary tiers

Security claims are meaningless without an adversary. We use five tiers, and we claim different things against each.

Table 3 — Adversary tiers and what CLOISTER claims

Tier	Capability	Canonical instance	Claim
A0	No document access; observes network / storage only	Harvest-now-decrypt-later collector; cloud storage breach	Prevented. Reduces to the security of AES-256-GCM and the hybrid KEM.
A1	Authorised reader, careless, unmodified software, no intent to evade	Associate who drags the memo into a chatbot to summarise it; student who uploads the PDF	Prevented. Keys never reach a process with egress; if the file left the perimeter, extraction yields the decoy.
A2	Authorised reader, motivated to evade, uses off-the-shelf tools	Runs OCR on a screenshot; tries three PDF libraries; asks a vision model	Cost imposed and traced. Must abandon automation, accept ~10× inference cost and OCR error, and still ships a fingerprinted copy.
A3	Technically skilled; reverse-engineers the client; scripts capture; recruits colluders	Coalition of five recipients diffing their copies to strip the watermark	Traced. Collusion-resistant code names a colluder; see §5.5. Prevention is not claimed.
A4	Kernel or hypervisor privilege on the reading device; physical access; can subvert attestation	Rooted endpoint; malicious IT administrator; state actor	Not defended. Stated as an explicit non-goal.

2.2 The analog hole, and the narrower thing usually confused with it

These are two different problems and conflating them cost this project a draft.

The analog hole proper is the reader's own eyes, memory and hands. Retyping a paragraph, dictating it, or simply remembering it cannot be prevented by cryptography, by an operating system, or by a document format. That channel is open permanently and no part of this paper claims otherwise.

Optical capture — a screenshot, a photograph, a video recording — is a different matter, and treating it as part of the analog hole was a mistake. It is mediated by a device whose sampling behaviour differs from the eye's in ways that are structural rather than perceptual, and §4.7 exploits that difference. Some of these paths close completely; one closes with an exact zero-information guarantee; others do not close at all. §5.9 says which is which.

What is worth noticing is how *bad* the analog hole is for the adversary, and CLOISTER is designed to keep it bad. It is slow, it does not scale past a few pages, it produces transcription errors, and — critically — a photograph of a CLOISTER-rendered page still carries the kerning fingerprint, so even the paths that stay open stay attributable (§5.6). The design goal is to make the analog hole the *only* hole, and to make using it expensive and traceable.

2.3 What we are protecting against, precisely

The threatened event is not "a model reads the text." It is:

THREAT EVENT

A *complete and faithful* copy of the document's semantic content is transferred into an inference system, at *low marginal effort*, without the owner's authorisation, in a manner that is *not attributable* to a specific recipient.

Each italicised qualifier is a lever. Remove completeness and the model's answer is wrong. Remove fidelity and the model's answer is wrong in an undetectable way — which is worse for the adversary. Raise effort and most incidents simply do not happen, because they are acts of convenience, not espionage. Remove non-attributability and the deterrent becomes real, because consequences become assignable.

2.4 The security property, stated formally enough to argue with

Let D be a document, R the set of authorised recipients, and Ext an extraction procedure available to an adversary. CLOISTER aims at:

P1 (No cheap faithful path). For every Ext whose marginal cost is within a small constant of "open the file and read the bytes," the semantic content recovered from a CLOISTER artefact is negligible.

P2 (Posture precedes plaintext). No content key is derivable except by a process whose runtime posture satisfies the policy digest bound into the key derivation. Policy downgrade is equivalent to key destruction.

P3 (Attribution under collusion). For any copy or fragment recovered by a coalition of at most c recipients, the tracing algorithm outputs a member of that coalition with probability $1 - \epsilon_2$, and accuses a non-member with probability at most ϵ_1 , for parameters chosen by the distributor.

P1 and P3 are measured in Section 5. P2 is enforced by construction and tested adversarially, including against an attacker who holds the distributor's signing key. Note what is *not* claimed: nothing about A4, nothing about human memory, and no unconditional statement about vision models — Section 5.4 reports exactly how well the vision path works, because pretending otherwise would be dishonest.

2.5 Explicit non-goals

- Preventing a determined human from transcribing content they may lawfully read.
- Defending a device whose kernel or hypervisor is under adversary control.
- Detecting whether a given piece of text was written by a model — a different and, we argue in §4.6, poorly posed problem.
- Interfering with, degrading, or injecting instructions into third-party AI systems. See §10.2.
- Preventing lawful discovery, regulatory inspection, or accessibility use. The design must make authorised access *easier*, not harder, or it will be switched off.

3 Five design principles

1 • BIND KEYS TO POSTURE, NOT TO IDENTITY

The question "who are you?" is answerable by a compromised machine. The question "can plaintext leave the process you are about to become?" is answerable only by the platform, and is the question that actually matters. Every access decision in CLOISTER is a statement about the *runtime*, with identity as one input among several.

2 • FAIL CLOSED, AND MAKE THE FAILURE CRYPTOGRAPHIC RATHER THAN PROCEDURAL

A policy check that a client could skip is not a control. CLOISTER folds the policy digest into the key-derivation transcript, so a client that ignores the policy derives a key that does not decrypt anything. The enforcement is not "the viewer refuses"; it is "the mathematics refuses."

3 • DEGRADE FOR MACHINES, NEVER FOR HUMANS

Any measure that makes a document harder for a legitimate reader — including a reader using a screen reader or a magnifier — will be disabled by users within a week. The chaff layer is therefore *visually lossless*: the rendered page is pixel-for-pixel the true document. Accessibility is handled by exposing a genuine accessible text channel to attested assistive technology (§10.3), not by degrading the page.

4 • PREFER A PLAUSIBLE WRONG ANSWER TO AN OBVIOUS REFUSAL

This is the least obvious principle and the one that most distinguishes CLOISTER from prior extraction-hardening work. An automated pipeline that receives garbage *knows* it received garbage, and escalates — to OCR, to a vision model, to a human. A pipeline that receives fluent, plausible, correctly-shaped text **stops**. Section 5.4 measures the difference: classic glyph-permutation output is statistically conspicuous, and CLOISTER's decoy is not.

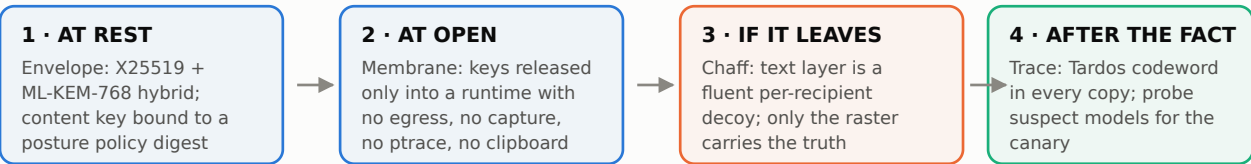
5 • ASSUME THE PERIMETER HAS ALREADY FAILED, AND PRICE THE LEAK

Every copy is unique from the moment it is created. This costs nothing at distribution time and converts the eventual, inevitable leak from an unresolvable mystery into a named individual — which is the only mechanism that has ever reliably changed human behaviour around confidential material.

4 Architecture: four layers

Where each layer intervenes

the document's journey, left to right, and what CLOISTER does at each stage



INGESTION PATHS THIS ADDRESSES

● Drag-and-drop into a consumer chatbot	blocked at 2, degraded at 3
● Browser AI sidebar reading the open tab	blocked at 2 (no capture, no DOM egress)
● Agent / MCP server with filesystem access	blocked at 1 — envelope never opens for it
● Coding assistant indexing a repository	blocked at 1
● OS-level assistant screenshotting the screen	blocked at 2 via capture exclusion
● Enterprise suite auto-indexing the file store	blocked at 1
● Recipient photographs the screen with a phone	not prevented — traced at 4
● Recipient retypes or dictates the content	not prevented — traced at 4 if verbatim

Figure 1. The four layers map onto four moments in a document's life. Layers 1 and 2 are preventive and require a cooperating platform; layer 3 travels with the file and works anywhere; layer 4 is unconditional and operates after the fact. The lower panel is the ingestion-path inventory from §1.2 with the responsible layer named, including the two paths that are honestly marked as not prevented.

4.1 Composition, and why each layer is insufficient alone

The layers are deliberately redundant, because each fails differently. The envelope alone is defeated the instant an authorised user opens it on a permissive machine. The membrane alone is irrelevant once the file is copied to a device without the runtime. Chaff alone is defeated by a vision model. Tracing alone prevents nothing. Composed, an adversary must defeat a cryptographic binding, a kernel-enforced information-flow boundary, a rendering-layer divergence, *and* a collusion-resistant code — and the last one has no technical defeat, only the choice not to leak.

4.2 Layer P1 — The Envelope NOVEL BINDING

A CLOISTER envelope is a COSE/CBOR structure with three parts: a policy, a key-encapsulation block, and an AEAD-protected body. The content key is derived as:

```
ss = HKDF-SHA384( ss_X25519 || ss_MLKEM768 || ct_X25519 || ct_MLKEM768 || H(policy) || suite )
KW = AES-256-GCM(ss) → wraps CK, AAD = H(policy)
BODY = AES-256-GCM(CK) → wraps D, AAD = H(header)
```

Why hybrid, and why these parameters. ML-KEM (FIPS 203) is the NIST standard key-encapsulation mechanism; ML-DSA (FIPS 204) and SLH-DSA (FIPS 205) are the standardised signature schemes, with FN-DSA (FIPS 206) still in draft as of this writing.^[3] We use ML-KEM-768 concatenated with X25519 rather than either alone: the combiner is secure if *either* primitive survives, which protects against both a future quantum adversary and an implementation break in the much newer lattice scheme. Both ciphertexts are bound into the transcript, following the same rule that governs the TLS hybrid designs — otherwise an adversary who can maul one ciphertext can produce a related key.

For the legal constituency this is not speculative hygiene. Documents whose confidentiality must hold for decades are precisely the harvest-now-decrypt-later target, and an envelope is a self-contained ciphertext that an adversary can simply keep.

The policy digest is load-bearing. $H(\text{policy})$ appears twice: inside the KDF transcript and as AEAD associated data. This is the mechanism behind principle 2. An adversary who edits the policy to remove `egress_blocked` does not obtain a permissive envelope; they obtain an envelope whose key derivation no longer reproduces the wrapping key. Section 5.2 verifies this holds even when the adversary also controls the distributor's signing key — signature stripping is not a bypass, because the signature was never the enforcement.

Policy contents. Attribute predicates (matter number, role, institution), a posture requirement set, a validity window, a fingerprint-seed identifier, and a transparency-log endpoint. Attribute-based access is expressed as predicates evaluated by the local broker against verifiable credentials; we deliberately do *not* put ciphertext-policy attribute-based encryption on the critical path. CP-ABE is elegant and would let the ciphertext itself carry the policy, but practical post-quantum ABE is not production-ready, and a scheme whose security we cannot defend to a court is worse than a predicate check plus a signature. It remains a roadmap item (§12).

Leases make revocation real. The envelope never contains a permanently-usable key. The broker issues a lease — a short-lived token, sealed to the device's platform root of trust, that the membrane must present to re-derive the content key. Offline work is supported by lease duration, not by permanent release. Revocation then means "stop issuing leases," which actually works, unlike revocation in identity-based IRM where the recipient already holds a usable key.

Auditability. Every lease issuance is appended to a tamper-evident Merkle log in the manner of certificate transparency, with inclusion proofs returned to the requester. This is what converts "we think nobody opened it" into a defensible statement — the property that legal and compliance buyers actually pay for, and one that no gateway product can offer because gateways do not see access that happens off-network.

4.3 Layer P2 — The One-Way Membrane NOVEL APPLICATION

Decentralised information-flow control has a long research lineage — Asbestos, HiStar, Flume, Laminar — which never achieved adoption because it demanded that applications be rewritten against a new label model. CLOISTER's contribution is not the taint concept; it is the observation that **decryption is a natural, narrow, application-agnostic taint source**, and that the adversary of interest (an inference pipeline) needs a fat, easily-identified channel: a network socket, a clipboard, or a screen capture. You do not need whole-system label propagation to stop that. You need one process, launched already-confined, that never had those channels to begin with.

Ordering is the whole design. Posture is proven, then the key is derived. A sandbox applied after decryption protects nothing, because the plaintext already exists in a process that could have leaked it. In CLOISTER the reader process irreversibly enters the membrane *first*, then presents the resulting posture evidence to obtain the key.

What the membrane removes. On Linux, in the proof of concept: an empty network namespace (no interfaces, no routes, no resolver), a private IPC namespace, a seccomp-BPF filter that returns `EPERM` for sixteen syscalls covering socket creation of every address family, `connect/bind/listen/accept`, all `send/receive` variants, `ptrace`, and `process_vm_readv/writev`, plus `PR_SET_DUMPABLE 0` to close `same-uid /proc/pid/mem` reads and `PR_SET_NO_NEW_PRIVS` to prevent privilege re-acquisition. The filter is inherited across `execve`, which is what makes it cover the real renderer and any agent process that tries to attach itself downstream.

Landlock where available. Linux's unprivileged Landlock LSM is the right long-term substrate: filesystem scoping from ABI 1 (kernel 5.13), TCP `bind/connect` restrictions from ABI 4, abstract-UNIX-socket and signal scoping from ABI 6, and UDP rules at ABI 10.^[1] That progression matters because it closes exactly the lateral channels a seccomp filter handles bluntly. The kernel in our test environment (6.18.5) was built without Landlock, which the implementation

detects and reports rather than silently skipping — a detail worth stating, because "we applied a sandbox" claims should always be verified at runtime rather than assumed from a kernel version.

Capture exclusion. The screen is a channel, and in 2026 it is an increasingly automated one. On Windows, `SetWindowDisplayAffinity(WDA_EXCLUDEFROMCAPTURE / WDA_MONITOR)` is the documented mechanism by which a window's content is withheld from capture, and Microsoft names it as the way an application excludes itself from Recall snapshots.^[4] Recall is opt-in and shipped generally in April 2025 on Copilot+ hardware, which means a document owner cannot assume it is off on a recipient's machine — the exclusion call is not optional hardening, it is a requirement. macOS provides an equivalent window-sharing exclusion; Wayland can deny capture through the portal; X11 fundamentally cannot, and CLOISTER refuses to open protected content under a bare X11 session rather than pretend otherwise.

4.4 Layer D — Semantic Chaff NOVEL

This layer applies when prevention is impossible by construction: the document has to be emailed to opposing counsel, posted to a course site, or filed with a court.

The mechanism. In a PDF, what a human sees and what a machine reads travel through two independent channels: glyph selection (via the font's `CIDToGIDMap`) and character reporting (via the `ToUnicode CMap`). Nothing in the format requires them to agree, and no consistency check can detect disagreement without rasterising the page and running OCR. CLOISTER builds a `CIDFontType2` in which the CID space is expanded so that each distinct (*visible glyph, reported character*) pair receives its own CID. The page renders the true document; every text extractor reports the decoy.

The decoy is congruent, not random. This is the part that matters. The decoy is generated to be geometrically identical to the true document — same word count, same per-word character lengths, same punctuation positions, same capitalisation pattern — and composed of real English words drawn from an innocuous topical lexicon. The word choice is driven by a keyed PRF over (*recipient identifier, word index*), which gives the decoy a second job: **it is itself a per-recipient fingerprint**. Recovering the decoy identifies which copy was ingested. One artefact, two functions — degradation and attribution — and the second is free.

WHERE THE PROOF OF CONCEPT IS WEAKER THAN THE DESIGN

Our decoy generator selects length-matched real words from a topical lexicon, so the output is lexically real and structurally perfect but not grammatical — it reads as word salad on close inspection. Production should generate the decoy with a constrained-decoding language model under the same length and punctuation template, keyed identically, producing fluent prose. This is straightforward and we have not built it. Section 5.4 nonetheless shows that the current output is already statistically indistinguishable from natural language by the measure a pipeline would plausibly use.

Why not just strip `ToUnicode`? Because that is the prior art, and it produces gibberish, and gibberish is a signal. Section 5.4 quantifies this: gibberish sits far outside the compression profile of natural language, so a competent pipeline detects it and escalates to OCR — which recovers everything. The chaff approach removes the escalation trigger.

Additional degradation options, deployable per-policy: reading-order permutation in the content stream; per-page re-keying so that a single recovered mapping does not compromise the document; homophonic expansion of the CID space so that classical frequency analysis of the reported text is starved; and raster-only pages for the highest sensitivity tier. We regard raster-only as a last resort because it is hostile to accessibility.

4.5 Layer T — Traitor tracing and the ingestion oracle

The code. Every distributed copy carries an m -bit codeword from a symmetric Tardos probabilistic fingerprinting code.

^{[10][11]} Tardos's construction is the right choice because its length is $O(c^2 \log(1/\epsilon_1))$ — independent of the number of

recipients except logarithmically — and because it is provably collusion-resistant under the marking assumption, meaning a coalition that compares its copies and constructs a hybrid still cannot escape. The original constant was $100 \cdot c^2 \cdot \ln(1/\epsilon_1)$; refinements bring the practical constant near the asymptotic optimum of $\pi^2/2 \approx 4.93$, which is what we use.

The embedding channels, in decreasing robustness:

Channel	Capacity	Survives	Defeated by
Inter-word kerning micro-offsets measured in §5.6	122 positions per page 1 bit per 2 gaps	Printing, photography, screenshots, 72–300 dpi, JPEG q40, blur, noise, rotation once deskewed — BER 0.000	Retyping; uncorrected rotation; blur beyond ~3 px
Glyph-variant selection	~0.5 bit per glyph	Rasterisation, moderate rescaling	Font substitution; heavy compression
Chaff decoy word choice	~1 bit per word	Text extraction, copy-paste of the text layer	OCR path (decoy is absent from the image)
Lexical / synonym substitution in the visible text	~0.1 bit per word	Retyping, copy-paste, light paraphrase, OCR	Heavy paraphrase; model-mediated rewriting

The channels are complementary by design: the kerning channel survives the analog hole, the chaff channel survives the digital one, and the lexical channel survives retyping. A leak through *any* path retains at least one channel.

The redundancy schedule. A standard traitor-tracing deployment assumes the whole work leaks. The AI threat model does not: the canonical incident is someone pasting two paragraphs into a chat box. A codeword laid out once across a document is starved by such a fragment. CLOISTER therefore embeds each code bit at R independent locations, so that a fragment of relative size s yields $\text{Binomial}(R, s)$ observations per bit, resolved by majority vote. Section 5.5 measures the effect and it is large: choosing R for the shortest fragment you care about is the difference between tracing nothing and tracing a single paragraph.

The ingestion oracle **WITHDRAWN**. Tracing answers "whose copy is this?" once you hold the leaked text. A separate question is "did model M ingest document D at all?" An earlier draft of this paper proposed answering it by probing a suspect model for the document's canary, on the theory that a document seen in training leaves a detectable trace. We built the measurement and the answer is no, for two independent reasons — one empirical and one that should have been obvious without an experiment. §5.7 reports both. The component is withdrawn from the architecture rather than carried as future work.

4.6 Layer A — Authorship provenance: inverting the academic problem

NOVEL; NOW IMPLEMENTED, §5.8

For assignments, the preventive framing is partly wrong. A professor's real requirement is not "the student must not be able to feed this to a model" — it is "the submission must be the student's own work." Those are different claims, and the second is provable while the first is not.

AI-text detection attempts the second claim by inspecting the artefact, which does not work: the signal is weak, the false-positive cost is a wrongly accused student, and the bias falls on non-native English writers.^[13] Vanderbilt disabled Turnitin's detector for precisely this reason.^[12]

The alternative is to attest the *process*. A CLOISTER-aware editor maintains a hash-chained edit trail and emits a signed credential asserting verifiable properties of it — incremental character-level authoring, no bulk insertion above a threshold from an unattested source, plausible inter-keystroke timing distribution, revision count — bound to the submission's hash in the manner of C2PA content credentials. The professor verifies a credential rather than running a

classifier. A student who writes normally passes automatically; a student who pastes 2,000 characters from elsewhere produces a credential that says so, without anyone inspecting their prose style.

The privacy problem, and the answer. A keystroke log is surveillance. No student should hand one to an institution, and no institution should want custody of one. The design therefore commits to the trail locally and discloses only *predicates* over it: the credential proves "no single insertion exceeded N characters" without revealing the text, the timings, or the revision history. This is implemented and measured in §5.8 — the zero-knowledge layer turned out to need no general-purpose proving system, only Pedersen commitments and range proofs over a handful of committed integers. §10.1 treats the ethics, which we consider a first-order design constraint rather than a compliance afterthought.

4.7 Layer V — The display NOVEL; PARTIAL

Every spatial defence against OCR has lost. CAPTCHA-style distortion, adversarial perturbation, microtype: each degrades the page for the reader at least as much as for the machine, and vision models keep improving. So this layer does not attack the image. It attacks the *sampling*.

The asymmetry. A human integrates incident light continuously. A screenshot captures one composited frame. A rolling-shutter sensor integrates a different short slice per scanline. Those gaps follow from how framebuffer and CMOS sensors work, not from any property of perception that a better model could erode.

Construction 1, against the screenshot. Render the page as the time-average of two frames, $F1 = L + d$ and $F2 = L - d$ for a zero-mean mask. Confine the content to luminance $[1/3, 2/3]$ and both frames stay in range, so the average is exact rather than approximate. The eye integrates the pair and reads the document; a screenshot captures one frame. This needs no cooperation from the operating system, which matters because that is exactly what is unavailable on bare X11 and in a web viewer (§6).

THREE CONSTRUCTIONS THAT FAILED, AND WHY

Making the mask a second document *failed* — overlaying text of opposite polarity does not destroy glyph structure, and OCR reads straight through it (recovery 1.000). A block-structured mask survived high-pass filtering but fell to cell-median subtraction once the grid was aligned (0.973–1.000), and the grid is about 256 brute-force guesses scored by "does this read as English". A dense text-shaped mask fell to a four-level classifier (1.000), because near-binary content plus near-binary mask sums to four distinguishable levels and the map back to ink is injective.

The general reason none of them can work: mask amplitude is bounded by display headroom, headroom trades directly against the contrast the reader needs, so per-frame signal-to-mask is about 1 — and OCR beats that by aggregating over a glyph's many pixels. Lowering content contrast to widen the mask lowers it for the reader too, because the reader sees the average. **Single-frame secrecy is not achievable at human-readable contrast.** Construction 1 therefore defeats off-the-shelf OCR and raises cost; it is not secure.

Why no display-only scheme beats a recording. Suppose the display is a function of the document and time alone, and the adversary records every frame. The reader's retina integrates light over some window to give $R(W)$. The adversary holds every frame, so the adversary can compute $R(W)$ for any window, including the reader's. Anything legible to the reader is legible to the recording. This disposes of masking, keyed frame schedules and temporal secret sharing in one step, and it forces the shape of any solution: **the reader must hold a physical element that makes their optical path differ from the camera's.**

Construction 2, against the camera. Give the reader a shutter synchronised to the display, passing half the frames. Run a four-frame cycle at 240 Hz:

$A = L + d$	passed by the shutter
$B = L - d$	passed
$X = (1-L) + e$	blocked
$Y = (1-L) - e$	blocked
$(A + B) / 2$	$= L$ the reader sees the true page
$(A + B + X + Y) / 4$	$= 1/2$ uniform grey, exactly, pixel by pixel

The second identity holds independently of the masks, because $L + (1-L) = 1$ everywhere. A capture spanning whole cycles therefore contains *no spatial information* — not degraded information, none. An ordinary camera at $1/30$ s integrates eight display frames, which is two whole cycles. §5.9 reports what that measures out to.

Construction 3, the aperture bound. Render true text only inside a small window and fill the rest of the frame with decoy text. Any single capture then contains only the window's worth of true content, and the bound is on information present rather than on information obscured, so no image processing reaches past it. One detail matters and is easy to get wrong: the region outside the aperture must carry *different* information, not *faint* information. Attenuating the true text by a factor of twelve still lost the whole page, because ordinary autocontrast restores it.

Costs, which are real and fall on the reader. Construction 1 requires a 2:1 contrast ratio. Construction 2 halves the duty cycle, so the panel must run brighter, and needs 240 Hz hardware plus a shutter. Most seriously, frame alternation is a seizure and migraine trigger for photosensitive readers: it requires a warning, an opt-out, and an alternative route, on the same reasoning that keeps a wall-clock floor out of the default policy in §5.8. None of this applies to paper, which keeps only the chaff decoy and the kerning fingerprint.

5 Implementation and measurements

Everything in this section was built and run. The point of measuring rather than asserting is that two of the four results turned out to require design changes, both documented below.

5.1 What exists

Component	Status	Implementation	Measured in
Envelope (P1)	working	X25519 + ML-KEM-768 hybrid KEM, HKDF-SHA384 combiner, AES-256-GCM, CBOR/COSE-style header, Ed25519 header signature	§5.2
Membrane (P2)	working	Hand-built seccomp-BPF filter via <code>prctl</code> , network + IPC + UTS namespaces, Landlock probe	§5.3
Chaff (D)	working	PDF generator writing CIDFontType2 / Identity-H with divergent CIDToGIDMap and ToUnicode; keyed congruent decoy generator	§5.4
Tracing (T)	working	Symmetric Tardos code, five collusion attacks, redundancy schedule, accusation test	§5.5
Display layer (V)	partial	Complementary frame decomposition, the four-frame shutter cycle, and the aperture bound, with the attacks that break the first of them	§5.9
Analog channel (T)	working	Paired-gap kerning encoder plus an image-domain detector using analytic word windows and sub-pixel centroids	§5.6
Ingestion oracle	withdrawn	Measured and abandoned: canary-exposure study on a model with known ground truth	§5.7
Authorship provenance (A)	working	Hash-chained edit trail, Merkle commitment, attested-editor signature, and Pedersen/range-proof predicates disclosed in zero knowledge	§5.8

5.2 Envelope

Overhead is constant at **1,660 bytes** regardless of document size — ML-KEM-768 contributes a 1,088-byte ciphertext, X25519 32 bytes, and the remainder is the policy, nonces, wrapped key and signature. Sealing 10 MB took 136 ms; unsealing took 15.7 ms, i.e. **636 MB/s**, which means the cryptography is not the bottleneck for any realistic document. Device key generation (both keypairs) took 5.0 ms.

The adversarial tests matter more than the timings:

- **Fail-closed on every posture predicate.** Five predicates were violated one at a time; all five denials occurred before any key material was derived.
- **Policy tampering with signature stripping** — rejected at signature verification.
- **Policy downgrade with a valid re-signature**, modelling an adversary who has compromised the distributor's signing key — rejected at `InvalidTag`, i.e. the AEAD unwrap failed because the KEK no longer reproduced. This is the

property that distinguishes the design from conventional signed-policy IRM: the policy is cryptographically load-bearing, not advisory.

5.3 Membrane

Inside the membrane, socket creation failed with EPERM for AF_INET, AF_UNIX and AF_NETLINK — the last matters because netlink is a common overlooked path to host configuration. An outbound HTTP request failed; curl executed as a child process also failed, confirming the filter is inherited across execve and therefore covers a downstream renderer or agent runtime.

The legitimate work was unaffected: rendering the protected PDF inside the membrane took **419 ms** against a **456 ms** unconfined baseline — within run-to-run noise, so the enforcement cost is not measurable at this granularity. Total child setup plus probe plus render was 552 ms. The Landlock probe returned ENOSYS on the 6.18.5 test kernel and was reported as unavailable rather than silently skipped.

5.4 Chaff

We rendered a one-page privileged legal memorandum and attacked it with the three text-extraction libraries that dominate real document pipelines, plus the rasterise-and-OCR path.

Confidential content recovered from a CLOISTER-rendered document

share of 24 probed sensitive terms recovered by each ingestion path

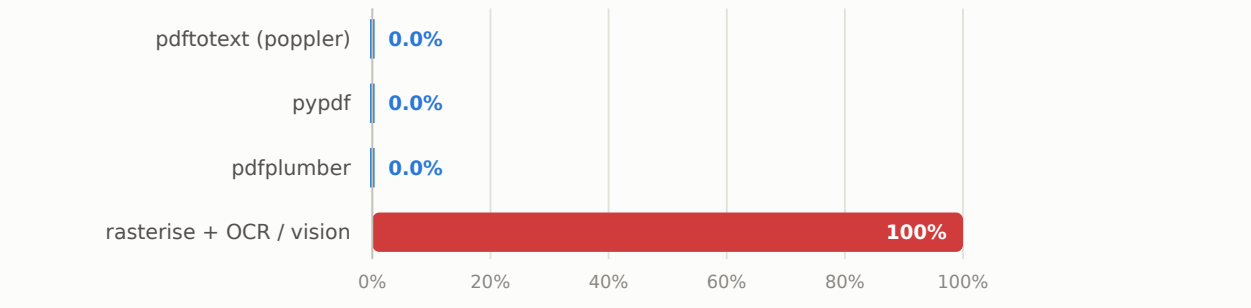


Figure 2. Recovery of 24 sensitive terms — the matter number, monetary amounts, percentages, and privilege-bearing vocabulary. All three text extractors recovered **none** of them; the digits they reported were substituted plausible digits ("55-OF-2468" for "17-CV-4821"). The OCR path recovered all 24, which is the honest limit of this layer.

Generic content-word overlap between the extracted decoy and the true document was 0.133, entirely from everyday vocabulary that both texts share ("assessment", "structured", "existing"). On the metric that matters — identifiers, amounts and privileged terms — recovery was zero.

Can an automated pipeline tell that it was fed a decoy?

zlib compression ratio of the recovered text

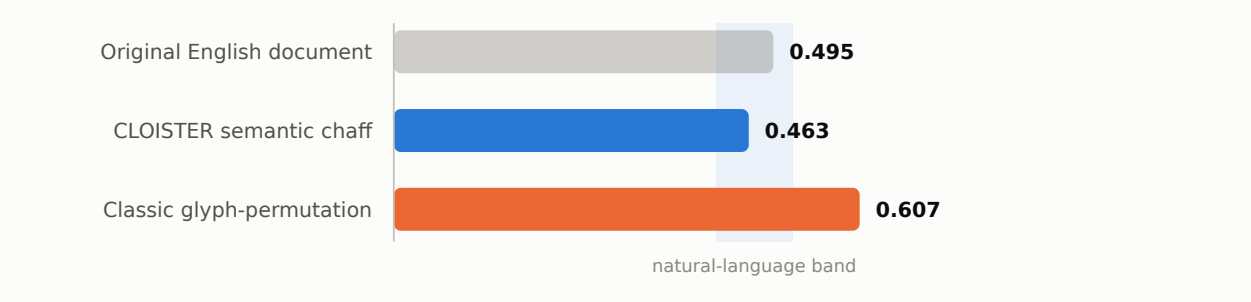


Figure 3. Whether the pipeline can tell it was fooled. zlib compression ratio is a cheap, standard proxy for "is this natural language": English prose compresses to roughly half its size, random letter strings do not. CLOISTER's decoy (0.463) sits inside the natural-language band alongside the original document (0.495). Classic glyph-permutation output (0.607) is conspicuously anomalous — which is what triggers a fallback to OCR and defeats the whole exercise.

This is the empirical argument for design principle 4. The prior-art technique and the CLOISTER technique are equally good at withholding content from a text extractor; they differ entirely in whether the extractor *notices*.

The cost of forcing the vision path. The true document is ~493 text tokens. Rasterised at 200 dpi, one page is ~4,987 image tokens — a **10.1×** inference-cost multiplier, plus OCR error, plus loss of document structure, plus the fact that most automated pipelines never attempt it. For an adversary processing one document this is an inconvenience. For an adversary processing ten thousand, it is a budget line.

5.5 Tracing

Code lengths follow $m \approx 4.93 \cdot c^2 \cdot \ln(1/\epsilon_1)$: 273 bits for a coalition of 2, 1,703 for 5, 6,812 for 10, at $\epsilon_1 = 10^{-6}$. With 1,000 recipients and the full document recovered, all five collusion attacks — majority, minority, coin-flip, all-ones and interleaving — were traced with probability 1.000 and zero false accusations.

FINDING 1 — A ONE-SIDED ACCUSATION TEST IS BLIND TO THE MINORITY ATTACK

Our first implementation accused on $S > Z\sigma$. Against the minority-voting attack it named **0.000** colluders — a complete failure, not a degradation, because minority voting produces a *negatively* correlated sequence that a one-sided test cannot see. Switching to a two-sided test on $|S|$ restored detection to 3.517 of 5 colluders named with zero false accusations. Any deployment that copies the textbook one-sided formulation inherits this hole.

Naming the leaker from a partial copy

P(at least one of 5 colluders identified) - 1,000 recipients - $m = 1,703$ bits
5-sigma two-sided accusation - 500 trials per point - majority-vote attack

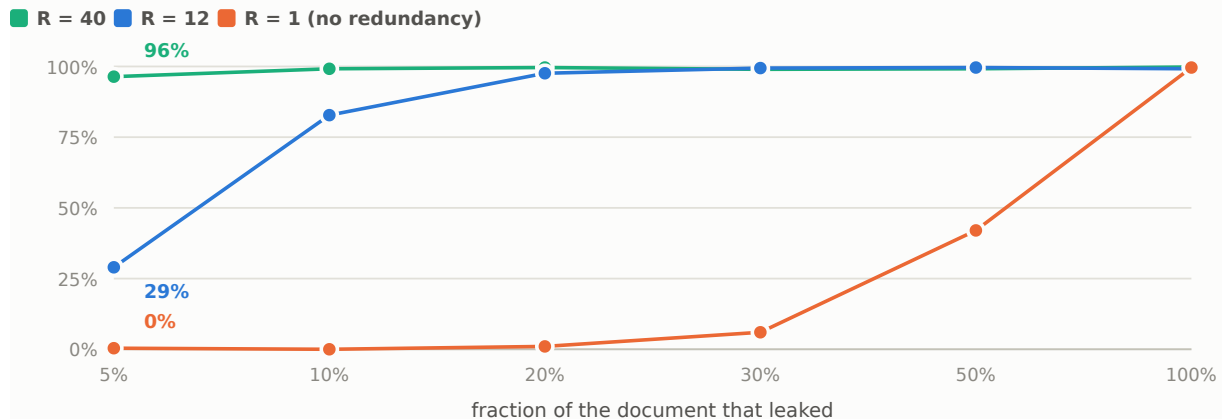


Figure 4. Tracing from a partial leak; majority-vote attack, 500 trials per point. Without redundancy ($R=1$, orange) the code is starved: at a 30% fragment detection is 6%, and below 20% it is nil — and worse than useless, because with so few observed positions the test also produced 0.11–0.32 false accusations per trial. With each bit embedded at 12 locations detection reaches 83% at a tenth of the document; at $R=40$ (green) a leak of **5%** — roughly one paragraph — names a colluder 96% of the time, with zero false accusations at both $R=12$ and $R=40$ across every point plotted. Redundancy is chosen for the shortest fragment the distributor cares about.

FINDING 2 — THE ACCUSATION THRESHOLD MUST SCALE WITH THE ROSTER

At 1,000 recipients, a 5σ threshold produced no false accusations. At 50,000 recipients — a realistic university — the same threshold produced 0.21 false accusations per trial, because the test is applied once per candidate and the multiple-comparisons burden grows with the roster. Raising the threshold to 6σ removed false accusations but collapsed detection to 48%, since the code was sized for the smaller population. The correct fix is to size the code for the roster: at $m = 2,555$ bits and 6σ , 50,000 recipients gave detection **1.000** with **zero** false accusations across 150 trials of every attack. The same effect appears when a code is starved by a short fragment: at $R=1$ and a 5% fragment the test produced 0.32 false accusations per trial while detecting essentially nothing. False accusation is the failure mode that matters here, and in both cases it is a parameter-selection problem that a naive deployment gets wrong.

5.6 The analog channel, measured

Section 2.2 asserted that a photograph of a CLOISTER-rendered page still carries its fingerprint. That claim was unmeasured in the first draft, and it is the load-bearing one for the whole attribution argument, so we built the channel and attacked it.

Each inter-word gap is displaced by a sub-perceptual amount, taken in *pairs that sum to a constant*: for a 1 bit the pair becomes (base + d, base - d), for a 0 the reverse. Line length is therefore invariant and displacement cannot accumulate along the line, so the right margin never moves and the perturbation stays strictly local. Detection compares the two gaps of each pair, which also cancels any global scaling introduced by printing or photographing. At 11 pt, $d = 0.275$ pt — 7.9% of a space advance — and one Letter page of running text carries **122 code positions**.

Extraction does not segment words out of the image. The document owner holds the master, so the detector computes each word's expected window analytically from the layout and takes an intensity-weighted centroid inside it. This matters more than it sounds: our first two detectors tried to find words by ink connectivity, and both failed at chance, because a single split or merged glyph shifts every subsequent gap index and inverts the bits that follow. The analytic window removes that failure mode entirely.

What the analog channel survives

bit error rate recovering the kerning fingerprint from an image of the page

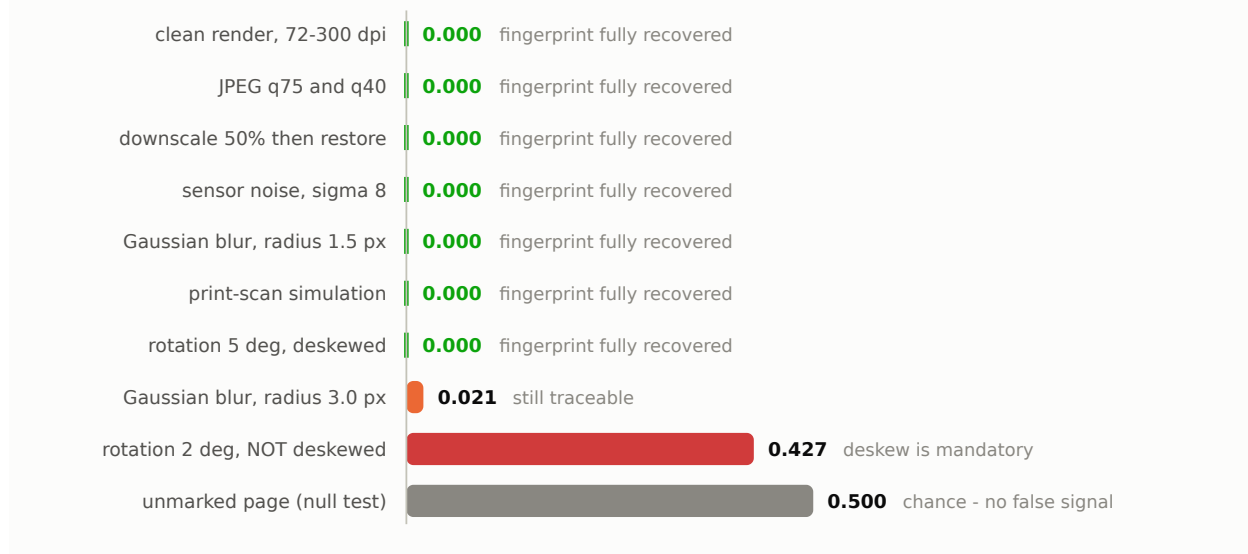


Figure 5. Bit error rate recovering the fingerprint from an image. Zero errors across resolution from a 72 dpi thumbnail to 300 dpi, JPEG down to quality 40, a 50% downscale-and-restore, Gaussian sensor noise, blur to a 1.5 px radius, a print-scan simulation, and rotation up to 5° once deskewed. It degrades gracefully at a 3 px blur and fails on *uncorrected* rotation — deskew is not optional. The null test is the important row: an unmarked page scores at chance with zero measured displacement, so the detector does not hallucinate a fingerprint that was never there.

End to end. We embedded one recipient's Tardos codeword, rendered the page, and put it through a simulated phone photograph — 1.3° rotation, 0.8 px blur, sensor noise, JPEG quality 70. All 122 positions on the page were recovered with **zero bit errors**, and the accusation named the correct recipient out of 1,000 with no false accusations.

FINDING 3 — AT THIS OBSERVATION COUNT THE TEXTBOOK THRESHOLD IS UNSAFE

One page yields 122 observed positions, and at that count the Tardos score is not reliably Gaussian: its tail is driven by however many small p_1 the code happened to draw. A fixed 5σ threshold produced **0.188 false accusations per trial**. Worse, the behaviour is not stable across code realisations — over 24 independently drawn codes at $m = 69$, detection ranged from **0.03 to 0.95** at the same nominal parameters. The fix is to calibrate the threshold against each code's own simulated null distribution at a chosen family-wise rate, and to screen candidate codes at generation time. Calibration drives false accusations to zero; the realisation still has to be chosen deliberately rather than assumed.

With the threshold calibrated per code, single-page tracing depends on how many people could have leaked it:

Table 7 — Naming a single leaker from one photographed page (122 recovered positions)

Recipients	Code bits	Calibrated threshold	Detection	False accusations	Detection at 5% BER
20	69	2.8σ	1.000	0.000	0.999
50	69	3.1σ	1.000	0.000	0.998
200	92	4.7σ	1.000	0.000	0.970
1,000	92	5.2σ	0.997	0.001	0.841

A trial team, a seminar, a board — the recipient lists that actually matter — are traced from a single photographed page with certainty and no false accusations. A thousand-name distribution needs more than one page. And a *coalition* is a different problem: five recipients diffing their copies cannot be traced from one page at all, and need on the order of fourteen pages of recovered material, because the collusion-resistant code is an order of magnitude longer.

5.7 The ingestion oracle, and why it is withdrawn

The oracle was the one component whose value depended on an unmeasured empirical claim, so it was the one most worth measuring. We trained a character-level neural language model where the ground truth is known — a canary of fixed format inserted into the corpus a controlled number of times — and measured the canary's *exposure* after training, following the method of Carlini et al.^[18]

Two methodological points first, because they determine whether the numbers mean anything. The gradients were verified numerically to a worst-case relative error of 5×10^{-8} ; a silent gradient bug would have produced whatever answer we went looking for. And the canary format was chosen small enough — 100,000 candidates — that the true canary's rank is computed *exactly* against every alternative rather than estimated from a fitted tail.

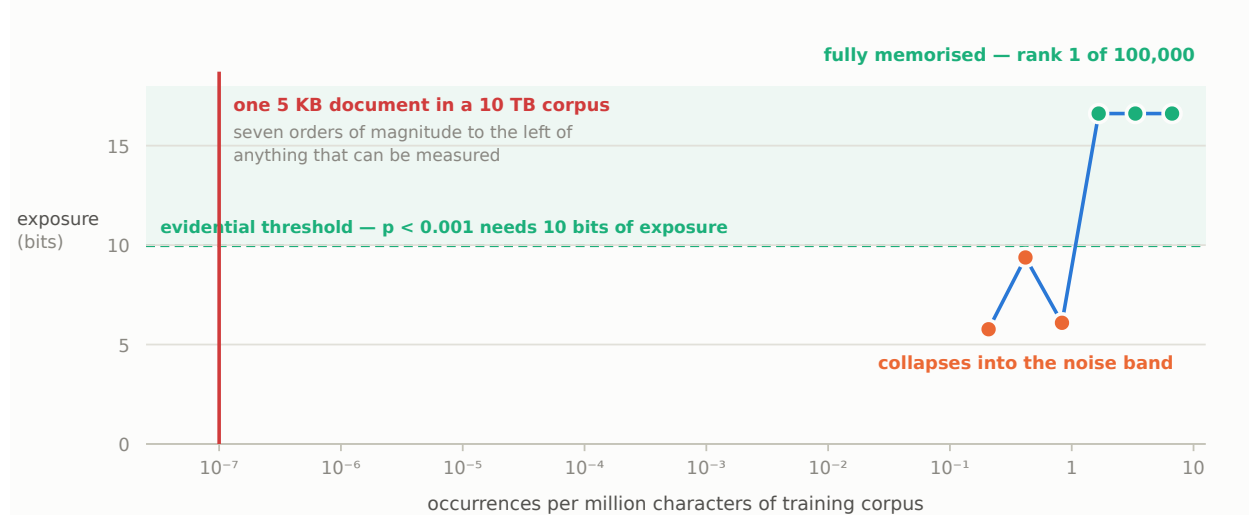
FINDING 4 — AN EXPOSURE FIGURE ALONE IS NOT EVIDENCE

In one control run a canary that had *never been inserted* scored 3.8 bits of exposure, because some digit strings are a priori more probable than others. Any oracle that reported that number as a finding would be manufacturing evidence. Under the null the true canary is exchangeable with every other candidate, so its rank is uniform and $P(\text{exposure} \geq x) = 2^{-x}$ exactly — the p-value is analytic. Claiming ingestion at $p < 0.001$ therefore requires about ten bits, and no smaller figure is worth reporting.

The ingestion oracle does not reach the density that matters

canary exposure against how densely one document sits in the training corpus

fixed compute (1.5 M gradient examples) · one occurrence · exact rank over 100,000 candidates



Does more model capacity rescue it? At a fixed density of 0.42 occurrences per million:

119k parameters	7.6 bits
236k parameters	8.9 bits
471k parameters	10.8 bits

crosses the threshold, just

Quadrupling the parameters buys about three bits. Closing seven orders of magnitude that way is not a plan.

Figure 6. Exposure against the density at which a single document sits in the training corpus, at a fixed compute budget so that only dilution varies. Above roughly 1.7 occurrences per million characters the canary is memorised perfectly — rank 1 of 100,000. Below about 0.8 it collapses into a band between 5 and 9 bits, which is not significant at any threshold that would survive scrutiny. The detection floor sits around one occurrence per million characters. A 5 KB document scraped once into a 10 TB corpus sits at 10^{-7} — seven orders of magnitude to the left. Quadrupling the model's parameters at fixed density buys roughly three bits, so capacity does not close that gap either.

The conditions favoured the oracle and it still failed. The corpus was small and repetitive, and the models reached a training perplexity of 1.08–1.18 — they had very nearly memorised everything they were shown, which is the most generous regime imaginable for canary recovery. A first sweep varying insertion count from 1 to 64 was uninformative for exactly that reason: every multiplicity gave perfect exposure, a ceiling effect rather than a result. Only when compute was fixed and the corpus grown — the condition a frontier model actually trains under — did the relationship become visible.

The second reason is architectural and needed no experiment. The oracle detects *training-time* ingestion: it asks whether a document was in the corpus. The canonical threat in this paper is *inference-time* — an associate uploads a privileged memorandum to a chatbot, a coding assistant reads a repository. None of that touches the weights, so there is nothing for an oracle to find. The component was aimed at scraping, which matters to publishers and authors, and not at the incident that motivates every user described in §1.1. That mismatch should have been caught in design review rather than in a measurement.

What replaces it. Nothing new is required, because the decoy already does the job for the threat that matters. If a model's *output* reproduces a document's per-recipient decoy, that is direct evidence of ingestion, it identifies which copy was ingested, it works at inference time, and it needs no access to the model's weights or training set. The capability the oracle was invented to provide already exists in Layer D, one section earlier.

5.8 Authorship provenance

Layer A was specified in §4.6 and has since been built, including the part the earlier draft deferred: the zero-knowledge disclosure. A student proves statements such as "no single insertion in my edit trail exceeded 400 characters" using

Pedersen commitments and bit-decomposition range proofs in a 2048-bit group with a 256-bit prime-order subgroup. Proving takes about 350 ms and verification about the same, each proof is 16 KB, and a three-predicate credential is 54 KB. Seven forgery attempts — retargeting the bound, tampering with either commitment, mutating a response, reordering and dropping bits, replaying under a different context — were all rejected, and the prover refuses to attempt a false statement rather than emitting a proof that will not verify.

The architecture has to solve two opposed problems, and conflating them is the trap. Zero-knowledge proofs give the student privacy but supply *no integrity whatsoever*: an author could commit to whatever statistics suited them and prove things about those. Integrity comes from elsewhere — an attested editor computes the statistics, commits to them, and signs the commitments alongside the trail root and the submission hash. The proofs then bind to values the author cannot change. A design that shipped only the proofs would look cryptographic and establish nothing.

A privacy audit of the output found and removed a leak: the number of edit events was being repeated in cleartext in the attestation body, although it was already committed. After that, of 861 recorded edit events, zero timestamps and zero statistic values appear anywhere in the credential. What the instructor learns is the policy bounds, pass or fail against each, the submission hash, the trail root, and which editor signed it.

Table 8 — Five simulated writing sessions, all producing the same length of text

Session	Verdict	Which predicates failed
Honest, deliberate (65 min)	credential complete	none
Honest, fluent (3 min)	credential complete	none
One bulk paste	incomplete	all three
Pasted in twelve chunks	incomplete	all three
Model output retyped by hand	credential complete	none — this is the limit

The last row is the fundamental limit, and the test suite asserts it rather than hiding it: this layer attests a *process*, not an *origin*. Someone who reads model output off a second screen and types it in at human pace satisfies every predicate. What changes is that the shortcut stops being free, and the honest student stops being at the mercy of a classifier.

FINDING 5 — A WALL-CLOCK FLOOR IS A FALSE-ACCUSATION MACHINE

The obvious predicate to add is a minimum elapsed time, and measuring it removed it from the default policy. Two simulated honest sessions producing identical output took 65 minutes and 3 minutes; a thirty-minute floor passes the first and fails the second. The second is a fluent writer, not a cheat. A floor penalises fluency, rewards leaving the editor open, and reproduces exactly the harm that §1.3 criticises detectors for. It ships disabled, behind an explicit flag, with the caveat attached. Rhythm statistics were excluded for the same reason and are worse: they misfire on dictation, on motor impairment, and on anyone drafting in a second language.

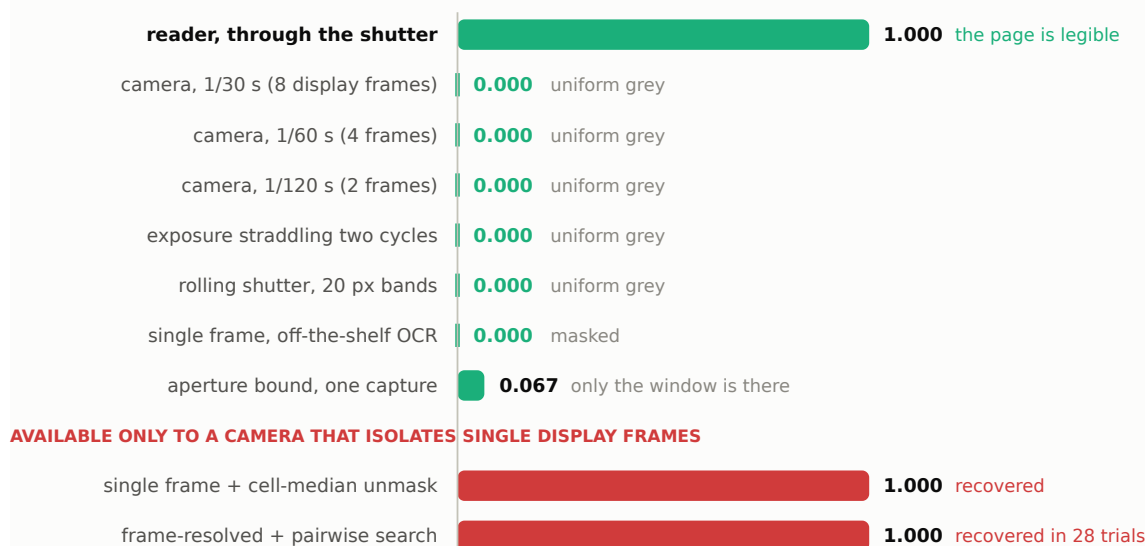
5.9 The display layer, measured

Every figure here is a true-content recovery against a page rendered by the four-frame cycle of §4.7, scored by running Tesseract on the capture with autocontrast applied — the attacker is given every advantage the harness can give.

What each optical capture path actually recovers

true-content recovery from a display running the four-frame cycle at 240 Hz;
the reader wears a shutter synchronised to pass half the frames

DEFEATED BY THE CONSTRUCTION



The full-cycle average is uniform grey to within $5.55\text{e-}17$ — exactly, pixel by pixel, because $L + (1-L) = 1$ everywhere. Such a capture holds no spatial information at all.

Figure 7. What each optical capture path recovers. Everything that integrates a whole display frame or more returns nothing, because the cycle's average is uniform grey — measured at 5.55×10^{-17} deviation, which is floating-point exact rather than merely small. That covers auto-exposure video and auto-exposure photography of a screen, including rolling shutter. What it does not cover is a camera that isolates a single display frame: a deliberate manual shutter around 1/500 s at 240 Hz, followed by cell-median unmasking or a pairwise frame search, recovers the page in full. The pairwise search found the complementary pair in 28 trials.

FINDING 6 — A KEYED FRAME SCHEDULE IS WORTH NOTHING

The obvious hardening is to keep the frame schedule secret so an adversary does not know which frames to combine. It fails, and not marginally: candidate combinations can be scored by "does the result read as text", which is a trivial test, so the search stays $O(n^2)$ over frame pairs and finishes in seconds. Secrecy of the schedule is not a security parameter. The only quantity that helps is how many frames the adversary's sensor can isolate.

The aperture bound behaves differently, and it is the only construction in this section whose guarantee is not contingent on the adversary's equipment. At apertures of 12 to 60 characters, a single capture recovered 0.053 to 0.067 of the document's content words and would need 33 to 165 separate captures to cover one page. That holds because the true text is *absent* from the frame outside the window, so there is nothing for a better attack to find. Its cost is borne in reading comfort, and we have not measured that.

5.10 Locking the numbers down, and what that turned up

Every claim above is now a named test, and every bug measurement found is a named regression test — 52 in total. The regression tests are built to an unusual rule, because the ordinary kind would not have helped here: each one registers *two* implementations, the fixed one and a faithful reconstruction of the original broken one, and asserts that the broken one *fails*. If it passes, the test is reported T00THLESS and the suite exits non-zero. This is mutation testing narrowed to the mutations that actually occurred, which is the subset already proven able to survive review. The harness also snapshots module state around every test, because a mutation is installed by monkeypatching and a mistaken restore does not look like a leak — it looks like five unrelated tests regressing at once, in another file.

Writing it found three more defects, which is the honest argument for having done it.

FINDING 7 — THE PHOTOGRAPH MODEL WAS THE WEAK LINK, NOT THE DETECTOR

Every degradation ladder in §5.4 held the page at full white. That hides two things at once: the uint8 clip discards the negative half of the sensor noise, and there is no paper pedestal for a threshold measured from zero to fall below. Give the detector grey, unevenly lit paper — an ordinary phone photograph — and it **failed at chance**, while its diagnostics still looked healthy. The tell was a median gap margin of 5.6 px against a 1.09 px signal: measurement error being read as signal. Two fixes were needed. A quadratic illumination surface is fitted from low-percentile samples and subtracted (six coefficients — enough for a ramp and the quadratic bowl of vignetting, too few to follow a text line), and what remains is thresholded relative to the local paper level with a noise-floor term. Re-measured across eight lighting conditions from flatbed scan to a dim room with off-centre vignetting, three recipients each: **24 of 24 traced, 0 false accusations**, bit error rate 0.0% in 20 of 24 and worst 2.9%.

The general lesson is uncomfortable and worth stating plainly: **the degradation model was written by the same people who wrote the detector**, and it was flattering in a way nobody noticed for an entire measurement campaign. A simulated attack ladder is a claim about the adversary, not a measurement of one.

FINDING 8 — EMBEDDED REDUNDANCY WAS BEING THROWN AWAY ON RECOVERY

The renderer cycles the codeword through however many gaps the document provides, so a page-filling page carries a 69-bit code about three times over. The detector assigned each position as it read it, so the last measurement silently overwrote the earlier ones and the redundancy bought nothing. Combining the repeats as *signed* evidence rather than as a majority vote on hard bits — a gap measured with a 2 px margin deserves more weight than one measured with 0.1 px — raises the combined margin from 1.01 px to 3.10 px, exactly the redundancy factor, and cuts the bit error rate on a dim photograph by roughly three.

FINDING 9 — A STALE RENDER IS A WRONG ACCUSATION

The rasteriser collected every image matching its output prefix, and the trace command reuses a fixed working directory. A one-page brief traced after an eight-page one therefore saw *eight* reference pages, seven belonging to a different document, and matched the evidence against whichever fitted best. Nothing warned. This is the worst class of bug this system can have, because its output is an accusation against a named person, and it was found by running the command-line tool twice in a row rather than by any amount of reading. The detector now also warns when gap margins are far larger than the embedded displacement, which is the signature of a misregistered page in general rather than of this one cause.

5.11 What these numbers do and do not establish

They establish that the mechanisms work as specified, on a real document, against the tools an adversary reaches for first. They do *not* establish that a determined adversary cannot recover the document — the OCR row of Figure 2 says plainly that one can. They measure OCR, not a multimodal model, which would likely do at least as well. They include no user study. The layer most important to the academic case is built but not deployable: it depends on an attested editor producing a real edit trail, and every measurement in §5.8 used synthesised trails instead. And after Finding 7, the sentence that deserves the most weight is this one: **every degradation figure here is a simulation**, and simulations written alongside the detector they test have already proven able to flatter it for months. Photograph real printed copies before relying on any of the tracing numbers.

6 Cross-platform enforcement

Layers P1, D and T are platform-independent: they are file-format and cryptographic constructions. Layer P2 is not, and honesty about per-platform capability is what separates a deployable design from a diagram. The distinction that matters throughout is **block** versus **observe** — a mechanism that can only report a violation after it happened is telemetry, not enforcement.

Table 4 — Membrane enforcement by platform

Control	Linux	macOS	Windows	Web viewer
Deny network egress to the reader process	Block netns + seccomp; Landlock ABI $\geq$ 4 for TCP, ABI 10 for UDP	Block Network Extension content filter; ESF auth events	Block WFP per-process filter; AppContainer	Block n/a — plaintext never reaches the client
Deny file writes outside a sealed scratch	Block Landlock FS; mount namespace	Block App Sandbox; ESF AUTH_OPEN	Block Minifilter driver	Block
Exclude window from screen capture	Partial Wayland portal denial; X11 cannot — but see the row below	Block Window sharing exclusion	Block SetWindowDisplayAffinity; also excludes from Recall ^[4]	No no web API can prevent capture
Gate clipboard writes	Partial Wayland compositor-mediated; X11 weak	Partial pasteboard is app-cooperative	Block clipboard format restriction in-process	Partial
Prevent debugger / memory inspection	Block seccomp ptrace deny + DUMPABLE 0	Partial hardened runtime; SIP-dependent	Partial PPL for signed processes	Block
Seal keys to hardware root of trust	Block TPM 2.0 policy session	Block Secure Enclave; App Attest	Block TPM 2.0 + VBS	No server-side custody instead
Defeat a single screenshot without OS help	Partial, platform-independent — complementary frame decomposition (§4.7) defeats off-the-shelf OCR on any single captured frame on every platform including bare X11 and the web viewer, and falls to a targeted unmasking attack. This is the only row here that does not depend on the operating system.			
Defeat a camera pointed at the screen	Blocked for ordinary equipment — the four-frame shutter cycle returns uniform grey to any capture spanning whole cycles (§5.9). Requires 240 Hz hardware and a shutter at the reader, and does not survive a camera that isolates single frames.			
Attest the renderer binary's identity	Partial IMA/EVM where enabled	Block code signing + App Attest	Block code integrity + attestation	Block

Two conclusions follow. First, **Windows and macOS are the strong platforms** for the membrane, which is the opposite of what a Linux-centric security design would predict; both offer capture exclusion and hardware key sealing that Linux desktops largely do not. Second, **the zero-install web viewer is the weakest posture but the most adoptable** — it keeps plaintext server-side so no key ever reaches an untrusted client, at the cost of being defenceless against screen capture. It is the right default for external recipients precisely because they will not install anything, and it should always be paired with layers D and T.

7 What is actually new here

Most of the primitives CLOISTER uses are not ours, and claiming otherwise would undermine the parts that are. The table separates them.

Table 5 — Prior art and delta

Element	Status	Prior art	CLOISTER's delta
Hybrid PQ key establishment	EXISTING	FIPS 203; TLS hybrid designs	Used as-is. Applied to documents rather than transport, motivated by decade-scale confidentiality horizons.
Encrypted container with rights policy	EXISTING	Purview Information Protection, Adobe DRM, Virtru, OpenTDF	Used as-is at the container level.
Posture-gated decryption	NOVEL	TPM sealing binds keys to <i>boot state</i> ; IRM binds to <i>identity</i> ; remote attestation reports posture <i>advisorially</i>	Binds the content key to a digest of a <i>runtime information-flow posture</i> — the demonstrated absence of egress, capture, clipboard and debug paths — and makes that digest load-bearing in the KDF, so policy downgrade destroys the key even for an adversary holding the signing key. Verified in §5.2.
Information-flow control / taint tracking	ADAPTED	Asbestos, HiStar, Flume, Laminar; CamFlow	Uses decryption as a narrow, application-agnostic taint source and confines <i>before</i> key release, avoiding the whole-system label propagation that blocked DIFC adoption. Targets inference pipelines specifically, which need wide channels.
Extraction-hostile documents	ADAPTED	Stripped or scrambled ToUnicode CMaps; glyph permutation; raster-only PDFs	All prior variants produce <i>detectable</i> gibberish, which triggers OCR escalation. Measured in §5.4.
Semantic chaff with congruent decoys	NOVEL	—	Text layer carries a fluent, length-congruent, topically coherent decoy, so extraction terminates confidently on the wrong document. Compression profile inside the natural-language band; no escalation trigger.
Decoy-canary duality	NOVEL	Canary tokens and honeytokens are separate inert artefacts	The decoy <i>is</i> the fingerprint: the same construction degrades the machine-readable copy and identifies which copy was ingested, at zero additional payload.
Collusion-resistant fingerprinting	EXISTING	Boneh-Shaw; Tardos; Škorić et al.	Code used as published, with the two parameter-selection corrections in §5.5.

Element	Status	Prior art	CLOISTER's delta
Fragment-sized redundancy schedule	NOVEL	Traitor tracing assumes the whole work leaks	Embeds each code bit at R locations sized to the shortest fragment of interest, because the AI threat model's canonical leak is a pasted paragraph. Turns an untraceable 5% excerpt into a 99% identification.
Sampling-asymmetry display	NOVEL, PARTIAL	Anti-screenshot displays; visual cryptography (Naor-Shamir); shutter-based 3D systems	Uses the reader's temporal integration as the decoding operator, so the page exists only as a time-average and no single frame carries it. Includes the necessity argument showing that no display-only scheme survives a full recording, and a four-frame cycle whose full-cycle average is provably information-free (§5.9).
Aperture information bound	NOVEL	Foveated rendering, used for bandwidth rather than secrecy	Bounds what a capture can <i>contain</i> rather than how legible it is, by filling the non-foveal field with decoy text instead of attenuated content. The only construction in this paper whose guarantee does not depend on the adversary's equipment.
Ingestion oracle	WITHDRAWN	Membership inference; data-provenance probing	Proposed, measured, abandoned. The detection floor is ~ 7 orders of magnitude above the density a single scraped document has, and the mechanism addresses training-time ingestion while the threat this paper describes is inference-time (§5.7).
Content provenance credentials	ADAPTED	C2PA / Content Credentials; document version history	Extended from "where did this file come from" to "was this text authored incrementally by a human", with predicate-only disclosure.
ZK authorship predicates	NOVEL, BUILT	Keystroke-log forensics; proctoring	Proves properties of an edit trail without disclosing it, replacing unreliable stylometric detection with a verifiable process claim and removing the surveillance requirement. Implemented and measured (§5.8), including the separation of privacy from integrity that the proofs alone cannot provide.

The defensible summary: **four novel mechanisms** (posture-gated decryption, semantic chaff, the decoy–canary duality, the fragment-sized redundancy schedule), **two novel designs not yet built** (the ingestion oracle, ZK authorship predicates), and a synthesis whose value is that the layers cover each other's failure modes.

8 Deployment postures

One protocol, four postures, chosen per recipient rather than per organisation. This matters because the interesting recipients are usually outside your control.

Posture	Recipient installs	Guarantee	Right for
Format-only	Nothing	Layers D + T. Text pipelines get the decoy; every copy is traceable.	Course handouts, filings, anything sent to a stranger. The adoption default.
Web viewer	Nothing (browser)	+ plaintext never leaves the server; access is logged and revocable	Opposing counsel, external reviewers, one-off recipients
Desktop viewer	Signed app, macOS / Windows / Linux	Full membrane: no egress, capture-excluded, hardware-sealed leases	Trial teams, research groups, anyone handling a matter repeatedly
Managed endpoint	App + platform policy	+ kernel-enforced filesystem and network scoping; renderer attestation	Firms and institutions with device management

The adoption path runs left to right, and the leftmost posture must be genuinely useful on its own — a professor should be able to protect an exam by exporting it through CLOISTER, with no infrastructure, and get the decoy and the fingerprint for free. Systems that require the recipient to cooperate before delivering any value do not get deployed.

9 Security analysis

Table 6 — Attacks and responses

Attack	Tier	Response and residual risk
Upload the protected PDF to a chatbot	A1	Defeated. The model receives the decoy and answers about facilities maintenance. Residual: a vision-capable model given the <i>rendered</i> page succeeds — but consumer upload paths overwhelmingly extract text first.
Screenshot, then OCR or vision model	A2	Cost imposed, traced. ~10× tokens, OCR error, lost structure, manual per-page effort. Under the desktop posture the capture itself is blocked, and under Layer V a single captured frame yields nothing to off-the-shelf OCR on any platform (\$5.9). The kerning fingerprint survives.
Frequency analysis on the reported text	A3	Addressed. A monoalphabetic mapping would be trivially solvable, which is why the construction is per-(glyph, reported-char) pair with per-page re-keying and optional homophonic expansion — there is no single small permutation to solve.
Strip the watermark by diffing several copies	A3	Traced. This is exactly the collusion model Tardos codes are proven against; \$5.5 measures five attack strategies. Residual: coalitions materially larger than the c the code was sized for.
Retype the document	A2	Partially traced. Kerning and glyph channels are destroyed; the lexical channel survives verbatim retyping. Heavy paraphrase defeats tracing. Effort scales linearly with length, which is the deterrent.
Photograph the screen, auto exposure	A2	Defeated under Layer V with the shutter: any exposure spanning whole display cycles records uniform grey, exactly (\$5.9). Without Layer V, not prevented but traced by the kerning channel.
Photograph with a deliberate short shutter, then unmask	A3	Not prevented, traced. Isolating a single display frame and applying cell-median unmasking recovers the page. Requires knowing the technique, setting a manual shutter around 1/500 s, and implementing a grid search — a materially higher bar than pressing a key, and the kerning fingerprint still survives.
Record the reading session on video	A3	Bounded, not prevented. No display-only scheme can beat a full recording (\$4.7), and the shutter cycle only helps if the sensor cannot isolate frames. The aperture bound caps what each capture holds; per-session frame watermarking makes the recording attributable.
Patch the viewer to skip the posture check	A3	Defeated. The check is not a branch in the client; the posture digest is in the KDF transcript. A patched viewer derives a key that does not decrypt (\$5.2).
Compromise the distributor's signing key	A3	Defeated for existing envelopes. Verified: re-signing a downgraded policy still fails AEAD unwrap. Newly issued envelopes are of course compromised.
Extract keys from the viewer's memory	A3/A4	Raised. ptrace denied, DUMPABLE 0, hardware-sealed leases with short lifetimes. A kernel-privileged adversary (A4) succeeds; not defended.
Ambient OS assistant captures the screen	A1	Defeated on Windows and macOS via capture exclusion; Windows' documented Recall opt-out is the same call. ^[4] Partial on Wayland, none on X11.
Local agent / MCP server reads the file	A1	Defeated. The envelope does not open for a process that cannot satisfy the posture policy, and an agent needs network egress by construction.
Framing an innocent recipient	A3	Bounded, not eliminated. The ϵ_1 bound covers statistical false accusation, and \$5.5's second finding shows the threshold must scale with roster size. It does <i>not</i> cover a recipient who deliberately re-embeds another's fingerprint — an open problem (\$13).
Denial of service on the lease broker	A3	Mitigated. Lease lifetimes permit offline work; a cached lease survives broker outage for its validity window. Availability is a genuine cost of revocability.

10 Ethics, law and misuse

10.1 Authorship provenance is surveillance unless designed not to be

A system that records how a student writes is a system that can be turned against them, and the history of proctoring technology is not reassuring. Three commitments are therefore architectural rather than policy: the edit trail never leaves the student's device; only predicates over it are disclosed, never content or timings; and the credential must be verifiable by the student before submission, so nobody is surprised by what their own tool asserted about them. A student must also be able to decline and be offered an alternative assessment route — a mandatory provenance regime with no opt-out will produce exactly the false-accusation harms it was meant to replace. We would rather ship a weaker guarantee than a stronger surveillance apparatus.

10.2 Why CLOISTER contains no prompt injection

An obvious temptation is invisible text instructing a model to refuse. We reject it, for four reasons that we think are dispositive. It is an attack on a third party's system rather than a protection of your own document. It is unreliable, and unreliable security is worse than none because it produces false confidence. It degrades legitimate accessible reading. And it may expose the sender to liability for interfering with a computer system they do not own. The chaff layer's decoys are therefore *inert*: they contain no instructions, only innocuous prose. This is a deliberate line and we think any serious product in this space has to draw it.

10.3 Accessibility is a first-class requirement, not an exception

A blind reader using a screen reader relies on exactly the text layer that chaff replaces. Handled badly, this technique locks disabled readers out of documents everyone else can read, which is both wrong and in many jurisdictions unlawful. The design answer: assistive technology is a first-class attested client. Under the desktop and managed postures, a screen reader that satisfies the posture policy receives the true text through the same lease mechanism as the renderer. Under the format-only posture — where no such gate exists — the document must ship with an accessible variant available on request, and the exported artefact should say so on its face. Any deployment that cannot meet this should not use the chaff layer.

10.4 Dual use

Tools that make documents hard for machines to read and hard to attribute can serve people evading legitimate scrutiny as easily as people protecting privileged material. The mitigations are structural: the transparency log makes access history auditable rather than deniable; envelopes carry a plaintext-visible policy so a recipient always knows what they hold; and legal-hold and lawful-process exemptions belong in the policy vocabulary from the first version, not bolted on later. A system marketed to lawyers that made discovery obligations harder to meet would be a liability to its own users.

11 Regulatory and market context

11.1 The obligations that create demand

- **Attorney duties.** ABA Formal Opinion 512 (July 2024) is the reference point: lawyers using generative AI must protect client confidentiality, and self-learning tools that may expose client information require informed consent.^[5] "We encrypted it and hoped" is not a defensible answer; an auditable access log is.
- **Discoverability of AI conversations.** The court-ordered production of roughly 20 million de-identified ChatGPT conversations in the New York Times litigation^[2] established concretely what was previously theoretical: a prompt is a record, and records are discoverable. Pasting privileged text into a consumer assistant creates a new evidentiary surface outside the firm's control. This is the single most persuasive fact in a legal-sector sales conversation.
- **EU AI Act.** Prohibitions and AI-literacy duties have applied since 2 February 2025; general-purpose model obligations since 2 August 2025; Article 50 transparency duties arrive 2 August 2026. The Digital Omnibus deferred high-risk obligations — Annex III standalone systems to 2 December 2027 and Annex I embedded systems to 2 August 2028 — and added a new Article 5 prohibition effective 2 December 2026.^[14] The deferral is worth stating plainly rather than overselling: the near-term compliance driver is transparency and provenance, not high-risk conformity assessment.
- **Trade-secret law.** Protection is conditioned on reasonable measures to maintain secrecy. As uncontrolled AI ingestion becomes foreseeable, the definition of "reasonable" moves, and a documented technical control becomes evidence.

11.2 The competitive gap

The AI-security category is well funded — SentinelOne's acquisition of Prompt Security, announced August 2025 at a reported ~\$250M, is the clearest marker — and almost all of it sits at the same architectural position: a gateway or browser extension on a managed device inside a managed network. That is a real product solving a real problem, and it is structurally incapable of protecting a document after it has been sent to someone else.

CLOISTER's position is the complement, not the competitor: protection that travels with the file. The two compose naturally — a gateway that recognises CLOISTER envelopes can enforce policy on egress, and CLOISTER can enforce policy where no gateway exists. The wedge is the recipient outside your perimeter, which is where both the professor's and the lawyer's actual problem lives, and which nobody is currently serving.

12 Roadmap and standardisation

Phase	Deliverable	Why this order
0-3 mo	Harden the chaff exporter: font subsetting, multi-page, DOCX and HTML inputs, constrained-decoding decoy generator, accessible-variant workflow. Ship the format-only posture as a standalone tool.	Zero recipient friction; delivers value on day one; the fastest route to real users and real feedback.
3-9 mo	Desktop viewer on macOS and Windows with hardware-sealed leases and capture exclusion; the lease broker and transparency log.	Table 4 shows these are the strong platforms. Windows and macOS first, not Linux.
6-12 mo	Authorship provenance: the protocol and its proofs are built (§5.8); what remains is the editor integration that produces a real trail, and a pilot in a small number of courses under an explicit opt-out.	Needs institutional partners and an ethics review more than it needs engineering.
9-18 mo	Ingestion oracle. Removed. The power study was run (§5.7) and the result was negative; the roadmap slot goes to hardening the decoy-as-evidence path instead — a registry that lets an owner check a suspect model output against their issued decoys.	The study cost days and saved a year. Publishing the negative result is the point.
12-24 mo	Display layer: a reference viewer implementing complementary decomposition and the aperture bound, plus a shutter prototype for the controlled-room tier. Photosensitivity review before any of it ships enabled.	The screenshot case needs only software and closes a gap the OS cannot. The shutter case needs hardware and a safety review, so it trails.
12-24 mo	Managed-endpoint enforcement: Landlock and eBPF-LSM on Linux, minifilter and WFP on Windows, Endpoint Security Framework on macOS. Post-quantum signatures (ML-DSA) alongside Ed25519. Evaluate CP-ABE for in-ciphertext policy.	Highest engineering cost, narrowest audience, and the part most easily replaced by platform features.

Standardisation. The envelope should be an open specification, not a proprietary format — a document confinement format that only one vendor can open reproduces the interoperability failure that has limited IRM adoption for twenty years. Three concrete tracks: an IETF-style specification of the envelope and the posture-attestation exchange, building on COSE and the RATS attestation architecture; a C2PA assertion type for authorship predicates, so provenance credentials verify in existing tooling; and publication of the chaff and tracing constructions with the measurement harness, so the claims in Section 5 can be checked and attacked. A security product whose central claims cannot be independently reproduced should not be trusted, including this one.

13 Limitations and open problems

ACKNOWLEDGED LIMITATIONS

- **Vision models defeat the chaff layer.** Figure 2 shows OCR recovering 100% of sensitive terms. Chaff imposes cost and removes the escalation trigger; it does not stop a determined adversary who rasterises.
- **The analog hole is open,** by construction and permanently.
- **A4 adversaries win.** Kernel privilege on the reading device defeats the membrane. Confidential-computing enclaves on the client would help and are not practically available for this use case today.
- **X11 cannot be secured by the operating system.** Layer V now gives a platform-independent partial answer for the single-screenshot case (§5.9), but a bare X11 session still offers no capture exclusion, and Layer V is not a substitute for it.
- **Single-frame secrecy is impossible at readable contrast,** and §4.7 gives the argument rather than treating it as an engineering gap. Everything in the display layer except the aperture bound is cost imposition.
- **The display layer asks the reader to pay.** A 2:1 contrast ratio, a halved duty cycle, 240 Hz hardware, a shutter — and flicker, which is a seizure and migraine trigger. It must ship disabled with an opt-out and an alternative route, and we have run no usability or safety study.
- **One layer was withdrawn, and one depends on a component we have not built.** The ingestion oracle was measured and abandoned (§5.7). Authorship provenance is implemented (§5.8) but is worthless without an attested editor producing the trail, and that editor does not exist yet — everything measured so far used synthesised trails.
- **No usability evidence.** Every result here is a machine measurement. The dominant failure mode of document security products is that people turn them off, and we have not measured that at all.
- **The decoy is not yet grammatical.** §4.4 documents the gap and the fix.
- **The analog channel needs deskewing and a calibrated threshold.** Uncorrected rotation beyond about a degree destroys it, and the accusation threshold cannot be taken from the textbook at single-page observation counts (§5.6, finding 3).
- **One page does not trace a coalition.** Single-leaker attribution from a photograph is solid; five colluders need roughly fourteen recovered pages.

OPEN PROBLEMS WE CANNOT CURRENTLY SOLVE

- **Watermark survival through model-mediated paraphrase.** If a recipient has a model rewrite the content, every embedding channel we have is destroyed while the semantics survive. Semantic watermarking that survives paraphrase is an active research area and, if solved, would be the single most valuable addition to this design.
- **Fingerprint framing.** A recipient who understands the kerning channel could re-embed another recipient's codeword. Cryptographically binding the fingerprint to something the recipient cannot forge — without giving them the extraction key — is unsolved here.
- **Statistical power of the ingestion oracle — resolved, and the answer was no.** Measured in §5.7. The detection floor sits about seven orders of magnitude above the relevant density, and the mechanism addressed the wrong ingestion path in any case. This line item is retained rather than deleted so the record shows what was claimed and what happened to it.
- **PCR brittleness in hardware sealing.** TPM policies bound to measurement registers break on legitimate firmware updates. Policy authorisation helps; the operational burden is real and is why many products quietly stop using it.
- **Accessibility under the format-only posture.** With no attestation gate, we cannot distinguish a screen reader from a scraper. The out-of-band accessible variant is a process answer, not a technical one, and we are not satisfied with it.

14 Conclusion

The instinct that motivated this work — that files need protection from being "dumped into AI models," and that content-side pleading cannot deliver it — is correct, and it points at a real architectural gap. Every deployed control today assumes the defender owns the environment where the document is opened. The documents that matter most are precisely the ones sent somewhere else.

CLOISTER's answer is to stop asking who is opening a document and start asking whether the runtime requesting the key has any path by which the plaintext could leave — and to make that question cryptographically load-bearing, so that a client which lies about it derives a key that does not work. Where prevention is impossible because the document must travel, it makes the machine-readable copy fluently wrong rather than obviously broken, so that automated pipelines stop instead of escalating. And it makes every copy unique, so the eventual leak has a name.

The measurements support the specific claims made and no more: zero of twenty-four sensitive terms recovered by the extraction libraries that real pipelines use; a decoy that those pipelines cannot detect; a policy binding that survives compromise of the signing key; sixteen egress paths closed at no measurable performance cost; a leaked paragraph — five percent of a document — sufficient to name one of five colluders at least 96% of the time with no false accusations in 3,000 trials; and a fingerprint that survives being photographed, recovered with zero bit errors from a simulated phone photo and naming the right recipient out of a thousand. Two of those results only exist because trying to break the design revealed that the textbook version was wrong.

What remains is the analog hole, which will remain, and two layers that are still designs. The honest claim is not that CLOISTER makes documents unreadable to machines. It is that it makes the easy paths fail, the hard paths expensive, and all of them attributable — which is the most that can be true, and considerably more than anything currently available to the professor with an exam to send or the associate with a privileged memo to file.

Appendix A Envelope schema and notation

```
CloisterEnvelope = {
  hdr   : bstr .cbor Header           ; canonical CBOR, signed and AEAD-bound
  sig   : bstr                       ; Ed25519 now; ML-DSA-65 alongside (roadmap)
  nonce : bstr .size 12
  body  : bstr                       ; AES-256-GCM(CK, D), AAD = SHA-384(hdr)
}

Header = {
  suite : tstr                       ; "CLOISTER-v1-X25519+MLKEM768-AES256GCM-SHA384"
  policy : Policy
  kem    : {
    ct_x25519 : bstr .size 32
    ct_mlkem768 : bstr .size 1088
    nonce      : bstr .size 12
    wrapped_ck : bstr .size 48 ; AES-256-GCM(ss, CK), AAD = H(policy)
  }
}

Policy = {
  matter      : tstr
  require     : { * tstr => bool } ; posture predicates, all must hold
  lease_seconds : uint
  not_after   : tstr               ; RFC 3339
  fingerprint_seed_id : tstr       ; per-recipient; keys chaff + kerning
  transparency_log : tstr          ; append-only Merkle log endpoint
}

Derivation
ss = HKDF-SHA384(ikm = ss_x || ss_k || ct_x || ct_k || H(policy) || suite,
  info = "cloister/kek", L = 32)
CK = AESGCM-Decrypt(ss, nonce, wrapped_ck, aad = H(policy))
D  = AESGCM-Decrypt(CK, nonce, body,      aad = H(hdr))

Release rule
derive(ss) is attempted only after the local broker verifies every predicate in
policy.require against live runtime evidence and a valid hardware-sealed lease.
Posture first, key second – the ordering is the security property.
```

Appendix B Parameter tables

Table B1 — Cryptographic parameters

Parameter	Value	Note
ML-KEM-768 encapsulation key	1,184 B	FIPS 203
ML-KEM-768 decapsulation key	2,400 B	sealed to platform root of trust
ML-KEM-768 ciphertext	1,088 B	dominates envelope overhead
X25519 public key / ciphertext	32 B	classical half of the hybrid
Envelope overhead (constant)	1,660 B	measured, all document sizes
Unseal throughput	636 MB/s	measured, 10 MB document
Seal / unseal, 100 KB	5.7 / 7.5 ms	median of 20
Device keygen (both keypairs)	5.0 ms	once per device

Table B2 — Fingerprint code sizing, $\epsilon_1 = 10^{-6}$ unless noted

Recipients	Collusion c	Code bits m	Threshold	Detection	False accusations
1,000	2	273	5σ	0.82-0.96	≤ 0.007
1,000	5	1,703	5σ	0.99-1.00	≤ 0.003
1,000	10	6,812	5σ	1.000	0.000
50,000	5	1,703	5σ	1.000	0.21 ← too high
50,000	5	2,555	6σ	1.000	0.000

Table B3 — P(at least one colluder named) by redundancy and fragment size
n = 1,000, c = 5, m = 1,703, 5σ two-sided, majority-vote attack, 500 trials per cell

Fragment leaked	R = 1	R = 12	R = 40
100%	0.996	0.992	0.998
50%	0.420	0.996	0.992
30%	0.060	0.994	0.990
20%	0.010	0.976	0.996
10%	0.000	0.828	0.992
5%	0.004	0.290	0.964

Appendix C Reproducibility

The proof of concept is five Python modules with no unusual dependencies beyond fonttools, cryptography, kyber-py and cbor2. Every figure and every number in Section 5 and Appendix B is produced by one of the commands below.

```
poc/chaff_pdf.py    CIDFontType2 generator: divergent CIDToGIDMap / ToUnicode
poc/decoy.py        keyed, length-congruent decoy generator
poc/envelope.py      hybrid PQ envelope, posture gate, adversarial tests
poc/membrane.py      seccomp-BPF + namespace confinement and egress probes
poc/kerning.py       paired-gap kerning encoder + image-domain detector, attacks
poc/tardos.py        symmetric Tardos code, 5 collusion attacks, redundancy
poc/kerning.py       paired-gap kerning encoder + image-domain detector, attacks
poc/final_measure.py extraction vs OCR vs control comparison
poc/sweep.py         fragment-size / redundancy sweep behind Figure 4
poc/figures.py       figure generation
```

```
$ python3 poc/chaff_pdf.py out/true_doc.txt out/decoy_doc.txt out/protected.pdf R-0001
$ python3 poc/final_measure.py          # Figures 2 and 3
$ python3 poc/tardos.py                  # §5.5 findings 1 and 2
$ python3 poc/sweep.py                   # Figure 4, Table B3
$ python3 poc/envelope.py                 # §5.2, Table B1
$ python3 poc/membrane.py                 # §5.3
$ python3 poc/kerning.py                  # Figure 5, Table 7
```

Environment: Linux 6.18.5 x86_64 (built without CONFIG_SECURITY_LANDLOCK),
Python 3.11.15, poppler pdftotext, pypdf 3.17.4, pdfplumber 0.11.9,
tesseract for the OCR path. Tardos experiments seeded at 20260725.

References

1. Linux kernel documentation, *Landlock: unprivileged access control* — ABI version history through ABI 10. docs.kernel.org/userspace-api/landlock.html

2. Coverage of the order requiring OpenAI to produce ~20 million de-identified ChatGPT conversations in the New York Times litigation, affirmed on review (reported January 2026).
3. NIST post-quantum standards: FIPS 203 (ML-KEM), FIPS 204 (ML-DSA), FIPS 205 (SLH-DSA), finalised August 2024; FIPS 206 (FN-DSA) in draft as of mid-2026.
4. Microsoft Learn, *Recall overview and Filtering apps, websites and sensitive information in Recall* — `SetWindowDisplayAffinity` as the application exclusion mechanism; Recall generally available 25 April 2025 on Copilot+ PCs, opt-in.
5. ABA Standing Committee on Ethics and Professional Responsibility, *Formal Opinion 512: Generative Artificial Intelligence Tools*, 29 July 2024.
6. Microsoft, *Announcing the sunset of Windows Information Protection* (2022) and migration guidance to Purview Information Protection.
7. CVE-2025-53109 and CVE-2025-53110 (reference MCP filesystem server: sandbox escape and symlink bypass); CVE-2025-6514 (mcp - remote command injection).
8. Documented MCP incident timelines, including prompt-injection-driven exfiltration of private repository contents and the 2026 STUDIO transport design flaw.
9. Cloud Security Alliance research note, *MCP Security Crisis: Systemic Design Flaws in AI Agent Infrastructure*, May 2026; NSA Cybersecurity Information Sheet on Model Context Protocol.
10. G. Tardos, *Optimal Probabilistic Fingerprint Codes*, STOC 2003.
1. B. Škorić, S. Katzenbeisser, M. Celik, *Symmetric Tardos fingerprinting codes for arbitrary alphabet sizes*; and subsequent constant-factor improvements (Blayer–Tassa, Furon et al., Laarhoven).
2. Vanderbilt University, *Guidance on AI Detection and Why We're Disabling Turnitin's AI Detector*, 16 August 2023.
3. W. Liang et al., *GPT detectors are biased against non-native English writers*, Patterns, 2023.
4. EU AI Act implementation timeline as amended by the Digital Omnibus agreement: Article 5 and AI literacy from 2 February 2025; GPAI obligations from 2 August 2025; Article 50 transparency from 2 August 2026; Annex III high-risk deferred to 2 December 2027; Annex I to 2 August 2028; new Article 5 prohibition from 2 December 2026.
5. SentinelOne, *SentinelOne to Acquire Prompt Security*, announced 5 August 2025; deal value reported at approximately \$250M.
6. Decentralised information-flow control lineage: Efstathopoulos et al. (Asbestos, SOSP 2005); Zeldovich et al. (HiStar, OSDI 2006); Krohn et al. (Flume, SOSP 2007); Roy et al. (Laminar, PLDI 2009).
7. N. Carlini, C. Liu, Ú. Erlingsson, J. Kos, D. Song, *The Secret Sharer: Evaluating and Testing Unintended Memorization in Neural Networks*, USENIX Security 2019 — the canary-exposure method used in §5.7.
8. IETF RFC 9180 (HPKE), RFC 9052 (COSE), RFC 9162 (Certificate Transparency v2), RFC 9334 (RATS architecture).

Reference entries without URLs above are given by title, venue and date so they can be located directly; the accompanying artefact bundle includes the full source list gathered during research.